

 ETHICAL HACKING BROWN BAG SERIES

Anatomy of a Binary Exploit: From Memory Corruption to Modern Mitigations

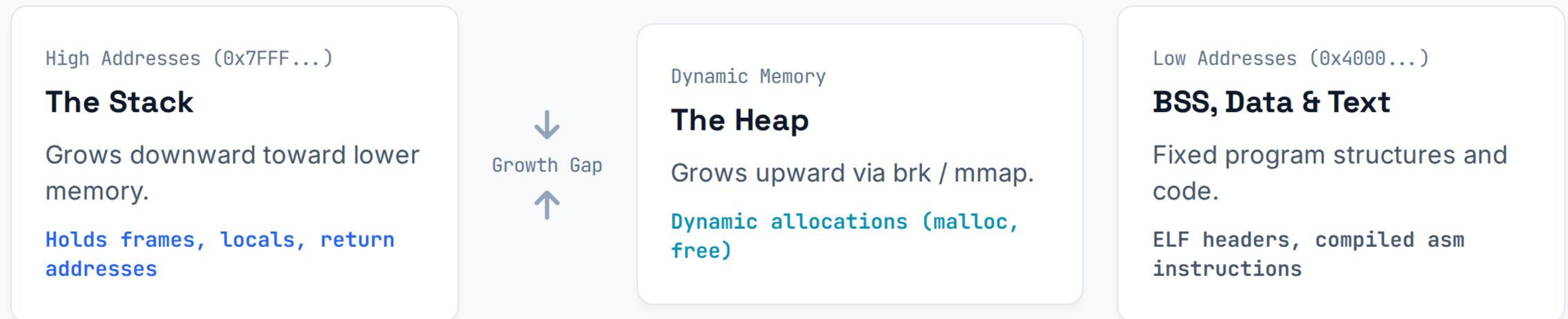
Understanding x86_64 stack dynamics, ROP mechanics, and modern hardware-enforced defenses.

 x86_64 System V ABI

 Return-Oriented Programming

 Intel CET & ASLR Defenses

Process Virtual Address Space



Anatomy of an x86_64 Stack Frame

Saved RIP (Return Address) 8 bytes [rbp + 0x8]

Saved RBP (Base Pointer) 8 bytes [rbp]

char buf[16] (Local Variables) 16 bytes [rbp - 0x10]

Control Pointer Placement

The return pointer resides directly above the frame pointer.

Contiguous Memory Alignment

Writing past 16 bytes immediately corrupts RBP and then RIP.

Deterministic Padding

Exactly 24 bytes of user data reach the return address.

Function Prologue & Epilogue

→] Prologue (Preamble)

```
push rbp
mov rbp, rsp
sub rsp, 0x10
```

Saves previous frame pointer and reserves local stack space.

[→ Epilogue (Postamble)

```
leave
; mov rsp, rbp; pop rbp
ret
```

Restores caller stack and pops saved RIP into instruction pointer.

x86_64 Argument Passing Convention

RDI

1st Argument

RSI

2nd Argument

RDX

3rd Argument

RCX

4th Argument

R8 / R9

5th & 6th Args



Exploitation Implication for `target(char* executable)`

Redirecting execution directly to `target()` fails unless register **RDI** points to a valid executable path.

What is Return-Oriented Programming (ROP)?



Gadget Snippets

Pre-existing instructions ending in ret.



Stack-Driven Flow

The ret instruction pops the next gadget address.



Bypasses NX / DEP

Executes existing code without shellcode injection.

OS & Compiler Defenses

`-fstack-protector`

Stack Canaries

Random token checked before ret
prevents hijacked control flow.

`-fPIE -pie + ASLR`

ASLR / PIE

Randomizes code offsets every
execution, invalidating static
gadgets.

`-Wl,-z,noexecstack`

NX / DEP

Marks memory non-executable,
preventing injected shellcode.

Modern ROP Neutralization

Intel CET Shadow Stack

Maintains an isolated, hardware-protected stack strictly for return pointers.

Mismatch on ret triggers immediate CPU fault (#CP).

ARM Pointer Auth (PAC)

Cryptographically signs return addresses using top unused pointer bits.

Altered pointers produce invalid hashes, terminating execution.

REMEDIATION

Remediation & Secure Coding

VULNERABLE (C89 / BANNED)

```
char buf[16];  
gets(buf); // Unbounded copy
```

No boundary check. Reads until newline.

REMEDIED (STANDARD C11)

```
char buf[16];  
fgets(buf, sizeof(buf), stdin);
```

Explicit capacity limit guarantees zero overflow.



Foundations Established

We understand the memory dynamics, ABI calling conventions, and modern defenses. Now let us build the exploit.

Next: Live Payload Walkthrough